

for the mail message (headers and body) that was received. If the two values match, this cryptographically proves that the mail originated at the purported domain and has not been tampered with in transit. The DKIM is depicted in Fig. 7.

2. SPF. Sender policy framework (SPF) is an e-mail authentication system designed to prevent e-mail spam by detecting e-mail spoofing, a common vulnerability, by verifying sender IP addresses. SPF allows administrators to specify which hosts are allowed to send mail from a given domain by creating a specific SPF record (or TXT record) in the domain name system (DNS). Mail exchangers use the DNS to check that mail from a given domain is being sent by a host sanctioned by that domain's administrators.

SPF can be implemented in three steps:

- 1. Publish a policy.** Domains and hosts identify the machines authorised to send e-mail on their behalf. They do this by adding additional records to their existing DNS information. Each and every domain name or host that has an 'A' record or 'MX' record should have an SPF record specifying the policy if it is used either in an e-mail address or as HELO/EHLO argument. Hosts which do not send mail should have an SPF record published that indicates such ("v=spf1 -all"). For validating the SPF record, one can use the testing tools provided on the SPF project Web page.

- 2. Check and use SPF information.** Receivers use ordinary DNS queries, which are typically cached to enhance performance. Receivers then interpret the SPF information as specified and act upon the result.

- 3. Revise mail forwarding.** Plain mail forwarding is not allowed by SPF. The alternatives are:

Re-mailing. Original sender is replaced with one belonging to the local domain.

Refusing. Reply 551 is given which says that user not local; for example, please try user@rakesh.com

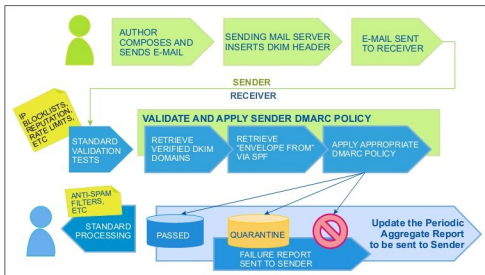


Fig. 8: DKIM, SPF together into action

Whitelisting. Done on the target server, so that it will not refuse a forwarded message

Sender rewriting scheme. Yet another option

Thus, the key issue in SPF is the specification for the new DNS information that domains set and receivers use. The records laid out below are in typical DNS syntax. Note that RFC 4408 recommended that both SPF and TXT records be used (during the transitional period), although either by itself was acceptable.

The sample SPF records are displayed below:

```
rakesh.com. IN TXT "v=spf1 a mx -all"
rakesh.com. IN SPF "v=spf1 a mx -all"
```

'v=' defines the version of SPF used. The following words provide mechanisms to use to determine if a domain is eligible to send mail. The 'a' and 'mx' specify the systems permitted to send messages for the given domain. The '-all' at the end specifies that, if the previous mechanisms did not match, the message should be rejected.

Comparing SPF and DKIM, we can say that SPF validates the message envelope (the SMTP bounce address), not the message contents (header and body). It is orthogonal and complementary to DKIM, which signs the contents (including headers). In brief, SPF validates MAIL FROM versus its source server; DKIM validates the 'From:' message header and a mail

body by cryptographic means.

One of the problems with DKIM is that if the message is significantly modified en route by a forwarding mechanism, such as a list server, the signature may no longer be valid and, if the domain specifies that all e-mail is signed, the message may be rejected. Also, many central antivirus solutions add footer that the e-mail has been scanned and the date of the signature files. Some free e-mail servers also add advertisements at the bottom of the e-mails. Many domains, however, say that only some of their e-mail is signed, and so a missing or broken signature cannot always be used to reject e-mail.

The solution is to sign all your e-mail. If the only modifications en-route involve the addition or modification of headers before the DKIM-Signature: header, the signature should remain valid. Also the mechanism includes features that allow certain limited modifications to be made to headers and the message body without invalidating the signature. We can suggest that this limitation could be addressed by combining DKIM with SPF, because SPF (which breaks when messages are forwarded) is immune to modifications of the e-mail data, and mailing lists typically use their own SMTP error address or Return-Path.

In short, SPF works without problems where DKIM might run